

DPDP COMPLIANCE AUDIT

finance-data-processing

Digital Personal Data Protection Act 2023



Grade A — Strong

Scanned: 08 April 2026

Files indexed: 14

Languages: Node.js, Express, PostgreSQL, dotenv, cors, helmet

CONFIDENTIAL — Internal Use Only

DPDP Compliance Scan Report

The application collects user credentials (email, password), personal details (name), and financial transaction data (amount, category, date, description, notes). The biggest DPDP risk is the potential for unauthorized access to sensitive financial records and user PII due to the storage of plaintext passwords (before hashing) and the broad access granted by JWTs.

Total findings: 13

HIGH: 1

MEDIUM: 2

INFO: 4

PASS: 4

Tech Stack: Node.js, Express, PostgreSQL, dotenv, cors

Risk Profile: The application collects user credentials (email, password), personal details (name), and financial transaction data (amount, category, date, description, notes). The biggest DPDP risk is the potential for unauthorized access to sensitive financial records and user PII due to the storage of plaintext passwords (before hashing) and the broad access granted by JWTs.

Compliance score by section

DPDP Section	Weight	Score	Status
Section 6	22	22/22 (100%)	PASS
Section 6(6)	8	8/8 (100%)	PASS
Section 8(1)	18	18/18 (100%)	PASS
Section 8	10	7.0/10 (70%)	WARN
Section 8(3)	8	8/8 (100%)	PASS
Section 8(4)	8	4.0/8 (50%)	WARN
Section 8(6)	8	6.8/8 (85%)	PASS
Section 9	6	6/6 (100%)	PASS
Section 11	6	6/6 (100%)	PASS
Section 16	4	4/4 (100%)	PASS
Section 5	2	2/2 (100%)	PASS
Section 13 — Grievance Redressal		0/4 (0%)	FAIL

Estimated Total Remediation Effort: 1.1–4.2 engineering days

Data Flow Analysis

The following PII flow signals were inferred via static analysis (import/call adjacency). These are heuristic code-path chains, not proven runtime traces. Use them to guide developer review (confirm actual request → handler → service → database paths in your app).

Flow 1: Application Logs

PII fields: password, email

auth.js → authController.js → database.js

Flow 2: Application Logs

PII fields: password, email, address

users.js → userController.js → database.js

Rule	Section	Severity	File
GRIEVANCE_OFFICER_MISSING	Section 13 — Grievance Redressal	HIGH	N/A
AUDIT_TRAIL_PARTIAL	Section 8(4) — Audit Trail	MEDIUM	N/A
INCOMPLETE_DELETION_COVERAGE	Section 8 — Data Principal Rights	MEDIUM	N/A
NO_BREACH_ALERTING	Section 8(6) — Breach	LOW	N/A
DATA_PORTABILITY_MISSING	Section 11 — Data Portability	LOW	N/A
INTERNAL_ROUTE_PII_ACCESS	Section 7 — Legitimate Use	INFO	src/routes/users.js
NO_THIRD_PARTY_DETECTED	Section 5 — Notice	INFO	N/A
NO_THIRD_PARTY_DATA_SHARING	Section 5 — Purpose Limitation	INFO	N/A
NO_CROSS_BORDER_DETECTED	Section 16 — Cross-Border Transfer	INFO	N/A
CONSENT_PRESENT	Section 6 — Consent	PASS	src/routes/auth.js
CONSENT_WITHDRAWAL_PRESENT	Section 6(6) — Consent Withdrawal	PASS	src/controllers/authController.js
DELETION_MECHANISM_PRESENT	Section 8 — Data Principal Rights	PASS	src/routes/records.js
DATA_ACCESS_PRESENT	Section 11 — Right to Access	PASS	src/routes/auth.js

30-Day Remediation Roadmap

The following plan prioritises findings by severity and estimated effort. Complete Week 1 items before your next security review.

Week 1 — Critical (1–4 hours)

Fix immediately — these represent the highest legal exposure.

- Grievance Officer Missing (1–4 hrs)

Week 2 — High Priority (4–16 hours)

Address within 2 weeks — short fixes with significant compliance impact.

- Audit Trail Partial (2–8 hrs)
- Incomplete Deletion Coverage (2–8 hrs)

Week 4 — Advisory (4–14 hours)

Address before next compliance review.

- No Breach Alerting (2–6 hrs)
- Data Portability Missing (2–8 hrs)

Total estimated remediation effort: 9–34 hours (1.1–4.2 engineering days)

Details

Finding 1 of 13

[Section 13 — Grievance Redressal]

1. [HIGH] GRIEVANCE_OFFICER_MISSING — N / A**Estimated fix time:** 1–4 hours

No compliant Grievance Officer / DPO publication found. A PASS requires grievance-related text or a dedicated route **and** a contact email or dedicated grievance/DPO URL. Tiny repos without a grievance route are not marked PASS.

Risk:

The absence of a designated Grievance Officer means individuals have no clear channel to raise concerns or complaints regarding their personal data processing, potentially leading to unresolved issues and non-compliance with data protection regulations.

Fix:

1. Create a new route (e.g., `/grievance`) that clearly displays contact information for the Grievance Officer.
2. Add a dedicated email address or a contact form for grievance submissions within the new route.
3. Update the API documentation (Swagger) to include the new grievance route and its purpose.
4. Ensure the Grievance Officer's contact details are easily accessible and regularly reviewed.

DPDP:

Section 13(1) — requires the appointment and publication of a Grievance Redressal Officer.

Example:

```
const express = require('express'); const router = express.Router(); router.get('/grievance',  
(req, res) => { res.json({ message: 'Grievance Redressal Officer Contact Information',  
officerName: 'Jane Doe', email: 'grievance.officer@example.com', phone: '+1-555-123-4567' });  
}); module.exports = router;
```

Finding 2 of 13

[Section 8(4) — Audit Trail]

2. [MEDIUM] AUDIT_TRAIL_PARTIAL — N / A**Estimated fix time:** 2–8 hours

Partial audit trail detected. Found: change tracking. Missing: access logging, audit model.

Risk:

The lack of a comprehensive audit trail, specifically missing access logging and a dedicated audit model, hinders the ability to track who accessed or modified personal data, making it difficult to investigate potential breaches or misuse and comply with accountability requirements.

Fix:

1. Implement middleware to log all incoming requests, including user ID, timestamp, and endpoint accessed.
2. Create a dedicated 'AuditLog' model to store detailed information about data access and modifications.
3. Integrate the audit logging middleware into the Express application pipeline before route handlers.
4. Ensure audit logs are stored securely and retained according to policy.

DPDP:

Section 8(4) — mandates the maintenance of an audit trail for all processing activities involving personal data.

Example:

```
const auditLog = require('./models/AuditLog'); // Assuming you create this model
app.use(async (req, res, next) => {
  const logEntry = {
    userId: req.user ? req.user.id : null, // Assuming user is attached to req
    timestamp: new Date(),
    method: req.method,
    path: req.path,
    ipAddress: req.ip
  };
  await auditLog.create(logEntry);
  next();
});
```

Finding 3 of 13

[Section 8 — Data Principal Rights]

3. [MEDIUM] INCOMPLETE_DELETION_COVERAGE — N / A**Estimated fix time:** 2–8 hours

Deletion mechanism detected but may not cover all PII storage. Uncovered files: src/config/database.js. DPDP Section 8 requires complete erasure of all personal data across all systems when a user requests deletion.

Risk:

Incomplete deletion coverage means that when a data subject requests erasure, personal data might persist in unintended locations, violating their right to be forgotten and potentially leading to continued unauthorized processing.

Fix:

1. Identify all locations where personal data is stored (databases, file systems, third-party services).
2. Implement a centralized data deletion service that can be called to remove data across all identified storage locations.
3. Ensure the deletion service handles cascading deletes or explicit removal from all related data structures.
4. Test the deletion process thoroughly to confirm complete data erasure upon request.

DPDP:

Section 8(2)(c) — grants data subjects the right to request the erasure of their personal data.

Example:

```
async function deleteUserData(userId) { // Example: Delete from primary database await
db.query('DELETE FROM users WHERE id = $1', [userId]); await db.query('DELETE FROM records
WHERE user_id = $1', [userId]); // Example: Delete associated files (if applicable) // await
fileStorage.deleteUserFiles(userId); // Example: Notify third-party services // await
thirdPartyService.deleteUser(userId); console.log(`User data for ${userId} deleted
successfully.`); }
```

Finding 4 of 13

[Section 8(6) — Breach]

4. [LOW] NO_BREACH_ALERTING — N / A**Estimated fix time:** 2–6 hours

Structured logging detected but no breach notification mechanism found. DPDP Section 8(6) requires notifying affected individuals and the Authority without undue delay when a breach occurs. Logging alone is insufficient — implement automated alerting (Sentry, PagerDuty, or equivalent) with escalation to a compliance team.

Risk:

The absence of a data breach notification mechanism means that in the event of a security incident, the organization cannot promptly inform affected individuals and the relevant authorities as required by law, increasing the risk of regulatory penalties and reputational damage.

Fix:

1. Define a clear process for identifying and assessing data breaches.
2. Implement a system for logging and tracking all security incidents.
3. Establish communication templates and procedures for notifying data subjects and the supervisory authority.
4. Integrate an alerting mechanism (e.g., email, webhook) to notify relevant internal teams upon detection of a potential breach.

DPDP:

Section 11(1) — mandates notification to data subjects and the supervisory authority in the event of a personal data breach.

Example:

```
function notifyDataSubjects(breachDetails) { // Logic to identify affected users based on
breachDetails const affectedUsers = getUsersAffectedByBreach(breachDetails);
affectedUsers.forEach(user => { // Send email or other notification
sendNotificationEmail(user.email, 'Security Alert', 'Your data may have been compromised...');
}); console.log('Data subjects notified.')} function notifyAuthority(breachDetails) { //
Logic to format and send notification to supervisory authority
sendAuthorityNotification(breachDetails); console.log('Supervisory authority notified.')} }
```

Finding 5 of 13

[Section 11 — Data Portability]

5. [LOW] DATA_PORTABILITY_MISSING — N / A**Estimated fix time:** 2–8 hours

No data export or portability endpoint detected. DPDP Section 11 requires Data Fiduciaries to provide personal data in a commonly used, machine-readable format upon request.

Risk:

The absence of a data export feature means users cannot exercise their right to obtain their personal data in a usable format, potentially leading to non-compliance with data portability requirements.

Fix:

1. Create a new Express route (e.g., `/api/users/:id/export`) to handle data export requests.
2. Implement a controller function that fetches user data based on the provided ID.
3. Format the user data into a commonly used machine-readable format such as CSV or JSON.
4. Set appropriate response headers (e.g., `Content-Disposition`, `Content-Type`) to facilitate file download.

DPDP:

Section 11(1) — Data Fiduciaries shall provide personal data in a commonly used, machine-readable format upon request.

Example:

```
router.get('/export/:id', authenticate, authorize('admin'), async (req, res) => { const userId = req.params.id; try { const userData = await userService.getUserData(userId); // Assume this fetches data if (!userData) return res.status(404).json({ error: 'User not found' }); const jsonData = JSON.stringify(userData, null, 2); res.setHeader('Content-Disposition', `attachment; filename="user-data-${userId}.json"`); res.setHeader('Content-Type', 'application/json'); res.status(200).send(jsonData); } catch (error) { res.status(500).json({ error: 'Failed to export data' }); } });
```

Finding 6 of 13

[Section 7 — Legitimate Use]

6. [INFO] INTERNAL_ROUTE_PII_ACCESS — src / routes / users.js

Internal file (users.js) accesses PII. Verify access is restricted to authorised contexts and PII is not exposed to logs or error responses.

Finding 7 of 13

[Section 5 — Notice]

7. [INFO] NO_THIRD_PARTY_DETECTED — N / A

No known third-party analytics or tracking SDKs detected in codebase.

Finding 8 of 13

[Section 5 — Purpose Limitation]

8. [INFO] NO_THIRD_PARTY_DATA_SHARING — N / A

No third-party data sharing detected.

Finding 9 of 13

[Section 16 — Cross-Border Transfer]

9. [INFO] NO_CROSS_BORDER_DETECTED — N / A

No foreign cloud or non-India region config detected.

Finding 10 of 13

[Section 6 — Consent]

10. [PASS] CONSENT_PRESENT — src / routes / auth.js

Framework auth/consent middleware detected in this file.

Finding 11 of 13

[Section 6(6) — Consent Withdrawal]

11. [PASS] CONSENT_WITHDRAWAL_PRESENT — src / controllers / authController.js

Consent withdrawal mechanism detected. Found in: src/controllers/authController.js (line 74)

Finding 12 of 13

[Section 8 — Data Principal Rights]

12. [PASS] DELETION_MECHANISM_PRESENT — src / routes / records.js

Data deletion mechanism detected. Found 2 deletion endpoint(s) and 7 deletion signal(s). Note: Verify deletion cascades to all PII tables (sessions, logs, related records).

Fix:

1. Verify deletion cascades to: sessions, audit_logs, third-party sync records.
2. Use database CASCADE DELETE or explicit multi-table deletion in deletion service.
3. Test deletion completeness: create account, delete, query all PII tables for orphaned data.

Finding 13 of 13

[Section 11 — Right to Access]

13. [PASS] DATA_ACCESS_PRESENT — src / routes / auth.js

Data access endpoint detected for authenticated users.

AI-Identified Compliance Gaps

The following gaps were identified by AI analysis and cross-validated. These are advisory observations, not verified rule violations. Human review is required before acting on these findings.

[AI-INFERRED] Incomplete user data access

Confidence: 60%

Section 8 Right to Access

The `GET /api/users/{id}` endpoint in `src/controllers/userController.js` retrieves user data, but the `GET /api/auth/me` endpoint also retrieves user data. There is no single endpoint that guarantees a user can download *all* their personal data as required by Section 8. The data flow indicates `GET /api/users/{id}` retrieves 'User ID', but the PII storage lists 'name', 'email', 'status', 'role' for this endpoint, suggesting more data is returned than just ID.

Recommendation: Implement a new endpoint, e.g., `GET /api/users/me/data`, that consolidates all PII associated with the authenticated user from all relevant tables (users, financial_records) and returns it in a downloadable format (e.g., JSON).

[AI-INFERRED] No age verification for registration

Confidence: 55%

Section 9 Children

The `POST /api/auth/register` endpoint in `src/controllers/authController.js` collects user name, email, and password. There is no mechanism to verify the age of the user during registration, which is a requirement if the service is intended for or could be accessed by children under the age of consent.

Recommendation: Modify the `POST /api/auth/register` endpoint to include an optional 'age' field. Implement validation to ensure the provided age meets the minimum age requirement. If the user is under the age of consent, block registration or implement parental consent flows.

[AI-INFERRED] Unclear PII usage in dashboard

Confidence: 35%

Section 5 Purpose

The `dashboardController.js` (endpoints like `GET /api/dashboard/summary`, `GET /api/dashboard/by-category`, etc.) retrieves financial data including 'date' fields. While financial data is expected, the PII storage lists 'date field' for multiple dashboard endpoints. It's unclear if this 'date' is solely for financial transaction analysis or if it's being used in a way that could infer user behavior patterns beyond the stated purpose of financial tracking.

Recommendation: Review the `dashboardController.js` logic to ensure that 'date' fields are only used for the explicit purpose of financial reporting and trend analysis. If any derived insights from dates could be considered PII or used for profiling, add specific consent or anonymization steps.

Deep Compliance Review

Overall Risk: HIGH

The application exhibits a critical risk due to the pervasive exposure of user email addresses across multiple API responses, potentially violating data minimization principles. Coupled with the lack of explicit consent for data collection during registration and insecure handling of JWT secrets, this creates a significant vulnerability for unauthorized access and misuse of PII. Addressing these cross-cutting issues is paramount to achieving DPDP compliance.

E

Most Critical Action: Modify all user retrieval and creation/update API endpoints to exclude the 'email' field from responses unless explicitly required for the immediate operation, ensuring adherence to data minimization principles.

- **PII Exposure in API Responses** [HIGH] — Article 24 (Data Minimisation) — layers: API Routes & Controllers, Third-Party & PII Flows
- **Insecure JWT Configuration** [MEDIUM] — Article 32 (Security Safeguards) — layers: Authentication & Session, Configuration & Secrets
- **Lack of Explicit Consent** [HIGH] — Article 4 (Consent) — layers: API Routes & Controllers

1. [HIGH] Email is returned in getAllUsers response — Third-Party & PII Flows — Article 24 (Data Minimisation)

Email is returned in getAllUsers response, violating data minimization.

2. [HIGH] Email is returned in getUserById response — Third-Party & PII Flows — Article 24 (Data Minimisation)

Email is returned in getUserById response, violating data minimization.

3. [HIGH] Email is returned in updateUser response — Third-Party & PII Flows — Article 24 (Data Minimisation)

Email is returned in updateUser response, violating data minimization.

4. [HIGH] Email is returned in user creation response — Third-Party & PII Flows — Article 24 (Data Minimisation)

Email is returned in user creation response, violating data minimization.

5. [HIGH] Missing explicit consent for registration data — API Routes & Controllers — Article 4 (Consent)

No explicit consent mechanism for user registration data collection.

Layer Breakdown

Configuration & Secrets — 1 finding(s). The configuration layer primarily handles database migrations. A minor issue was found regarding debug logging in the migration script, which could pose a low-level risk if executed in a production environment without proper log level management. No other DPDP-related architectural issues were identified in this layer.

Data Models & Storage — 0 finding(s). The database configuration appears standard and does not directly introduce DPDP compliance risks. It relies on environment variables for sensitive connection details, which is a good practice. No direct data handling or PII processing logic is present in this configuration file.

API Routes & Controllers — 1 finding(s). This layer defines API routes for authentication. A key compliance gap is the lack of explicit consent mechanisms for user registration, which is a fundamental requirement under DPDP for processing personal data. Other aspects like authentication and authorization middleware are present but do not mitigate the consent issue.

Authentication & Session — 3 finding(s). The authentication layer correctly uses bcrypt for password hashing and JWT for session management. It implements basic validation and authorization checks. However, there are minor areas for improvement regarding secure logging practices and robust handling of environment variables for JWT configuration.

Third-Party & PII Flows — 4 finding(s). This layer handles core user management operations. The primary compliance concern identified is the consistent return of email addresses in various user retrieval and creation/update responses. While email is often necessary, its inclusion in every response, including list views and creation confirmations, may violate the principle of data minimization and purpose limitation if not strictly required for the immediate purpose of the API call. The existing rule engine findings for missing grievance officer, partial audit trail, and incomplete deletion coverage are noted but not repeated here.